

Ledgr — Security Policy

Self-hosted personal finance · github.com/KenTaniguchi-R/ledgr · AGPL-3.0

Reporting a Vulnerability

If you discover a security vulnerability in Ledgr, **please do not open a public issue.**

Instead, report it privately via GitHub Security Advisories or email **taniguchi.ryusei@gmail.com** with:

1. Description of the vulnerability
2. Steps to reproduce
3. Potential impact
4. Suggested fix (if any)

You will receive a response within 48 hours. We will work with you to understand the issue and coordinate a fix before public disclosure.

Scope

The following are in scope:

- Authentication and session management
- Data isolation between households
- Encryption of sensitive credentials (Plaid tokens, AI API keys)
- OAuth flow for MCP server
- Plaid webhook validation
- SQL injection or other injection attacks
- Cross-site scripting (XSS)

The following are out of scope:

- Vulnerabilities in dependencies (report upstream, but let us know)
- Attacks requiring physical access to the host machine
- Self-hosted misconfiguration (e.g., exposing the app without HTTPS)

Security Architecture

- All monetary amounts are stored as integers (cents) to prevent floating-point errors
- **Plaid access tokens** are encrypted at rest at the application layer (AES-256-GCM, authenticated encryption with random per-value IVs). Keys are versioned and rotatable (`ENCRYPTION_KEY` , `ENCRYPTION_KEY_V2` , ...; see `pnpm rotate-keys`)

- **AI provider API keys** are supplied via the `AI_API_KEY` environment variable and are never persisted to the database
- **Other financial data** (transactions, balances, investment holdings) is stored in PostgreSQL. Encryption at rest for this data is the responsibility of the deployment — use a managed PostgreSQL instance that encrypts at rest, or a host with full-disk/volume encryption
- Household-based data isolation enforced at the query layer (`scopedQuery`)
- MCP access is gated behind OAuth with user-granted authorization
- No secrets are stored in the codebase — all credentials come from environment variables
- Transport security (TLS) is provided by the operator's reverse proxy; the application is intended to run behind an HTTPS-terminating proxy and never be exposed over plain HTTP

Vulnerability Management

Ledgr's code, dependencies, and container image are scanned continuously in CI:

- **Static analysis (SAST):** CodeQL (`security-and-quality` queries) on every push/PR and weekly
- **Dependency scanning (SCA):** Dependabot for npm, GitHub Actions, and Docker base images, with automated update PRs (weekly)
- **Secret scanning:** GitGuardian on every push/PR
- **Container image scanning:** Trivy scans the release image for known OS and library vulnerabilities **before it is published**. Fixable `CRITICAL` findings block the release; `HIGH / CRITICAL` findings are reported to the GitHub Security tab

Remediation SLA — identified, fixable vulnerabilities are remediated on this target timeline:

Severity	Target
Critical	Patch or mitigate within 7 days
High	Within 30 days
Medium / Low	Next regular dependency-update cycle

Supported Versions

Version	Supported
Latest	Yes